

RICHTLINIE FÜR SICHERE ENTWICKLUNG

VERSION	6
DATUM	04.09.2024
AUTOR	Michael Seefried
VERTRAULICHKEIT	Vertraulich
FREIGABE (PERSON+DATUM)	SEC-Team, 03.09.2024
EMPFÄNGER	DEV, OPS
SEITENZAHL	10

Inhalt

1. Dokumenteninformationen	3
1.1 Dokumenten-Code	3
1.2 Ansprechpersonen.....	3
1.3 Ziel und Umfang.....	3
1.4 Anwendung	3
2. Inhalt	5
2.1 Vor der Entwicklung	5
2.2 Während der Entwicklung	5
2.2.1 Rollen und Verantwortlichkeiten	5
2.2.2 Entwicklungsumgebung und Entwicklungswerkzeuge	5
2.2.3 Sicheres Systemdesign bei der Software-Entwicklung.....	6
2.2.4 Einhaltung einer sicheren Vorgehensweise bei der Software-Entwicklung.....	7
2.2.5 Umgang mit Test-Daten	7
2.2.6 Freigabeverfahren der entwickelten Software	7
2.2.7 Versionskontrolle	8
2.3 Weitergabe von Ergebnissen an Externe	8
3. Audit und Revision	9
3.1 Auditierung	9
3.2 Revision	9

1. Dokumenteninformationen

1.1 Dokumenten-Code

ISMS-RSE

1.2 Ansprechpersonen

Andreas Bachmann (ABA)
Adacor Hosting GmbH
Geschäftsführer (CEO)
Tel: +49 69 900299 22
E-Mail: andreas.bachmann@adacor.com

Michael Seefried (MSE)
Adacor Hosting GmbH
Informationssicherheitsbeauftragter
Tel.: +49 69 900299 2140
E-Mail: michael.seefried@adacor.com

1.3 Ziel und Umfang

Diese Richtlinie definiert grundlegende Vorgaben zur sicheren Entwicklung von Software. Zu dem Begriff Software zählt neben der "klassischen" Softwareentwicklung auch die Entwicklung von zentralen Scripten und Rollen (z.B. Ansible). Diese Richtlinie findet für die selbst entwickelte Software die auf den internen produktiven Servern betrieben wird Anwendung.

Für Kundenprojekte kann die Richtlinie ebenfalls als Anregung genutzt werden. Entgegenstehende Vorgaben aus der Beauftragung, dem Betriebshandbuch und anderen Richtlinien von Adacor oder von Kunden haben im Kundenprojekt Vorrang.

1.4 Anwendung

Diese Richtlinie gilt verbindlich für alle Mitarbeitenden im Bereich Operations und Development der Adacor Hosting GmbH (Adacor) ohne Ausnahme im Rahmen des ISMS. Verstöße gegen die Inhalte der Richtlinie können zu arbeitsrechtlichen Konsequenzen führen.

Zusätzlich können diese Vorgaben zur Beurteilung von ausgelagerter Entwicklung herangezogen werden.

2. Inhalt

2.1 Vor der Entwicklung

- > Dokumentation der Anforderung: Vor Beginn der Entwicklung müssen Anforderungen an das zu erwartende Ergebnis erhoben, bewertet und dokumentiert werden. Die Verantwortung für die Vollständigkeit der Anforderungen liegt in den Fachbereichen.
- > Wird im Rahmen des Entwicklungs- und Implementierungsprozesses auf externe Bibliotheken zurückgegriffen, müssen diese aus vertrauenswürdigen Quellen bezogen werden. Bevor externe Bibliotheken verwendet werden, muss deren Integrität sichergestellt werden.
- > Hinsichtlich Software aus externen Quellen, die als Grundlage für die eigene Entwicklungsarbeit verwendet wird oder werden soll, ist der lizenzkonforme Einsatz sicherzustellen. Dies gilt insbesondere bei Einbindung externer Bibliotheken oder auch der Verarbeitung von Lösungsansätzen aus externen Quellen. Fragen hierzu können an ISM gerichtet werden.

2.2 Während der Entwicklung

2.2.1 Rollen und Verantwortlichkeiten

Für ein geordnetes Vorgehen während der Softwareentwicklung sind Rollen und Verantwortlichkeiten projektspezifisch zu definieren.

2.2.2 Entwicklungsumgebung und Entwicklungswerkzeuge

- > Die Auswahl der Entwicklungsumgebung erfolgt primär anhand der für das Projekt vorgesehenen Programmiersprache und des geplanten Anwendungstyps.
- > Die Entwicklungsumgebung muss abgeschottet bzw. abgesichert betrieben werden. Die Entwicklungsumgebung ist ebenso wie die Testumgebung von der Produktionsumgebung zu trennen (siehe Abbildung).
- > Die Zugriffe auf Code-Repositories und die dazugehörigen Entwicklungsdaten müssen entsprechend dem Need-to-Know-Prinzip beschränkt werden.
- > Entwicklungswerkzeuge sind über den Softwarefreigabe-Prozess nach dem Konzept zur IT- und Internetnutzung freizugeben.

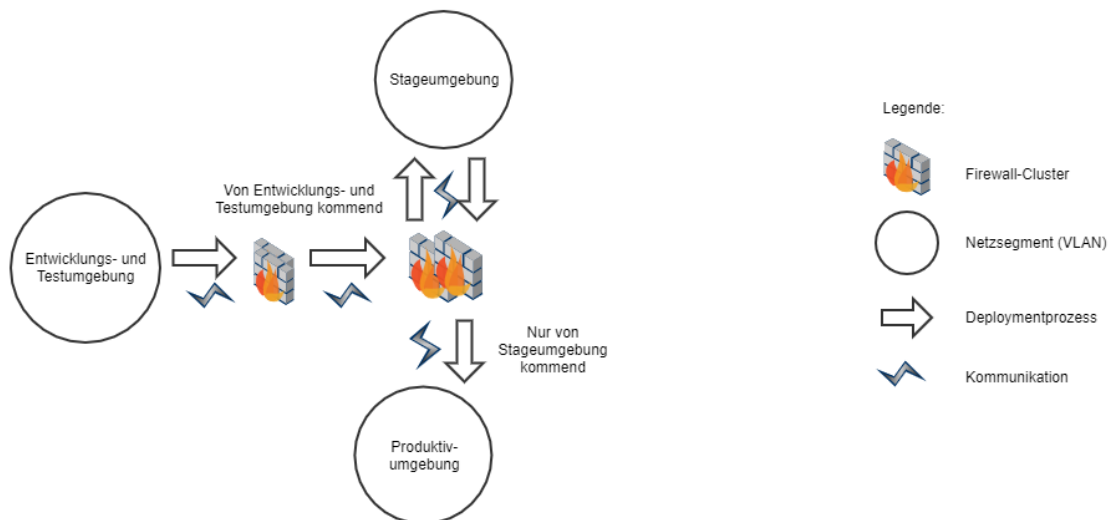


Abbildung: Grundsätzliche Darstellung zur Trennung der Entwicklungsumgebung zu der Produktivumgebung

2.2.3 Sicheres Systemdesign bei der Software-Entwicklung

Systeme sind so zu entwickeln, dass sie folgende Anforderungen erfüllen:

- > Eingabedaten sind vor der Weiterverarbeitung zu prüfen und zu validieren. Als ungültig klassifizierte Eingabedaten sollen verworfen und nicht weiterverwendet werden.
- > Bei Client-Server-Anwendungen sind die Daten grundsätzlich und primär auf dem Server zu validieren. Ausnahmen sind zu dokumentieren. Validierung auf dem Client findet nur zusätzlich statt, z.B. zur Verbesserung der Bedien- und Nutzbarkeit.
- > Zwischen Systemkomponenten sind Daten grundsätzlich verschlüsselt zu übertragen. Ausnahmen sind zu dokumentieren. Regelungen hierzu sind in der "Richtlinie zum Einsatz von kryptographischen Maßnahmen" enthalten.
- > Bei Fehlern oder Ausfall von Komponenten des Systems dürfen keine Informationen (z.B. Versionsnummern, Dateipfade oder sogar Passwörter) preisgegeben werden.
- > Der Betrieb der Software muss mit möglichst geringen Benutzerprivilegien möglich sein.

- > Grundsätzlich erfolgt die Authentifizierung gegenüber einem Verzeichnisdienst. Ist es notwendig eine eigene Authentifizierung zu implementieren, sind Passwörter vorab zu hashen, damit nur die Hashwerte gespeichert (z. B. in einer Datenbank) werden. Hierbei ist ein sicheres Hashverfahren zu verwenden.
- > Debugging-Funktionen sind grundsätzlich nur in der Entwicklungs- und Testumgebung zu aktivieren. Debugging-Funktionen in der Produktivumgebung sind nur in Ausnahmefällen und dann auch nur temporär zu aktivieren. Dabei ist sicherzustellen, dass die Debug-Funktionen aus der Produktivumgebung nur autorisierten Entwicklern oder Administratoren zugänglich sind und nach der Analyse des Fehlers wieder deaktiviert werden.

2.2.4 Einhaltung einer sicheren Vorgehensweise bei der Software-Entwicklung

Der Implementierungsprozess bei der Software-Entwicklung muss möglichst sicher gestaltet sein:

- > Es muss erkennbar und vermeidbar sein, ob und dass Software versehentlich geändert oder absichtlich manipuliert wird. Hierzu wird der Schreibzugriff auf den Quellcode nur nach dem Need-to-Know-Prinzip vergeben.
- > Sicherheitskritische Software-Komponenten, wie z.B. Authentisierungssysteme, müssen während der Entwicklung von mehreren Entwicklern geprüft und getestet werden.
- > Die Entwicklung wird nachvollziehbar und angemessen dokumentiert.

2.2.5 Umgang mit Test-Daten

- > Die Verwendung von betrieblichen Daten für Prüfzwecke die personenbezogene Daten oder andere vertrauliche Informationen enthalten soll vermieden werden.
- > Ist die Verwendung nötig, sollen möglichst alle sensiblen Details und Inhalte durch Zugriffsbeschränkung nach dem Need-to-know-Prinzip und z.B. Löschung oder Anonymisierung geschützt werden.
- > Falls personenbezogene Daten oder andere vertrauliche Informationen für Prüfzwecke verwendet werden sollen, muss diesbezüglich ISM oder der Datenschutzbeauftragte im Vorfeld einbezogen werden.

2.2.6 Freigabeverfahren der entwickelten Software

- > Es sind Verfahren zu implementieren und durchzuführen um die Qualität selbst entwickelter und auszuführender Software zu sichern, wie bspw. Code Reviews, automatische, statische Code Analysen, Black- oder White-Box-Tests. Die Tests

sind projektspezifisch bzw. der Software entsprechend auszuwählen und zu dokumentieren.

- > Es muss sichergestellt werden, dass regelmäßig bei Anpassungen Code-Reviews durchgeführt werden. Diese sind von unabhängigen Dritten durchzuführen oder von Entwicklern, die den Teil des Codes nicht selbst geschrieben haben.
- > Wenn externe Bibliotheken oder Code aus externen Quellen in die Entwicklungsumgebung eingebunden werden, sind diese vor Live-Gang auf Schwachstellen und mögliche Konflikte mit anderen bereits verwendeten Komponenten zu prüfen.
- > Sofern Code zur Einhaltung von Service Level Agreements benötigt wird darf er kurzfristig ohne 4-Augen-Prinzip getestet und freigegeben werden. Dieser Code muss nach Behebung des SLA Incidents unverzüglich durch eine weitere Person getestet und freigegeben werden. Besteht der Code das nachträgliche Testing nicht müssen alle gefundenen Fehler korrigiert und durch den Einsatz entstandene Risiken geprüft werden.

2.2.7 Versionskontrolle

- > Eine Versionskontrolle für die entwickelte Software ist zu gewährleisten.
- > Aus der Versionskontrolle müssen die Unterschiede zwischen Versionen ersichtlich und (dadurch) die Möglichkeit zur Rückkehr zu vorherigen Versionen möglich sein.

2.3 Weitergabe von Ergebnissen an Externe

Hinsichtlich der Weitergabe von Entwicklungsergebnissen an Externe gilt folgendes:

- > Die Weitergabe erfolgt erst nach offiziellem Auftrag des internen oder externen Auftraggebers oder nach von ISM oder der Geschäftsführung bestätigtem Antrag von Berechtigten am Entwicklungsergebnis.
- > Informationen, die für den Produktivbetrieb nicht relevant sind (z. B. Kommentare, Verzeichnisverweise u.ä.), müssen im ausgelieferten Programmcode und ausgelieferten Konfigurationsdateien entfernt werden.

3. Audit und Revision

3.1 Auditierung

Die Einhaltung dieser Regelungen ist alle 12 Monate stichprobenartig in Form eines internen Audits zu prüfen. Die betroffenen Mitarbeiter sind zur Kooperation verpflichtet.

Für die Erfolgsmessung dieses Dokuments sind folgende Kriterien zu prüfen:

1. Anzahl der Richtlinienverletzungen, die in den Audits festgestellt wurden.

3.2 Revision

Dieses Dokument soll alle 24 Monate einer Revision unterzogen werden.

Bisherige Revisionen:

REVISION	ÄNDERUNGEN	FREIGABE DURCH/AM	VERÖFFENTL ICHT AM	VERÖFFENTLI CHT VON
6	Punkt 1.3: Einschränkung des Scopes entfernt; Punkt 2.2.3: Erweiterung um den Umgang mit Debug-Funktionen	SEC-Team am 03.09.2024	04.09.2024	Michael Seefried
5	Punkt 3.2: Revision des Dokuments auf 24 Monate festgelegt; Redaktionelle Anpassungen	SEC-Team am 28.09.2022	28.09.2022	Michael Seefried
4	Redaktionell: Nummerierung der Zwischentitel, Aufbau der Richtlinie nach Prozess; Punkt 2.1 ergänzt: Anforderungserhebung des Ergebnisses, Sicherheitsprüfung der Bibliotheken; Punkt 2.2.3 ergänzt: Hinweis bezüglich Authentifizierungsinformationen; Punkt 2.3 ergänzt: Hinsichtlich der Weitergabe von Entwicklungsergebnissen	SEC-Team am 02.11.2021	08.11.2021	Michael Seefried
3	> Sprachliche Überarbeitung > Überarbeitung der Grafik nach Rückmeldung der Fachabteilungen > Konkretisierungen	SEC-Team über Comala am 25.11.2020	22.12.2020	Michael Seefried

- 1.4: Bereich Operations & Development
- 2 Berücksichtigung von Compliance-Anforderungen & Best-Practices, letzter Satz "im Besonderen eingefügt"
- 2 Sicheres Systemdesign bei der Software-Entwicklung: Primäre Validierung auf dem Server, Validierung auf Client nur zusätzlich erlaubt.
- 2 Test- und Freigabeverfahren der entwickelten Software: Falls personenbezogene Daten oder andere vertrauliche Informationen für Prüfzwecke verwendet werden sollen muss diesbezüglich ISM oder der Datenschutzbeauftragte im Vorfeld einbezogen werden.

2	Ergänzung der Grafik bei Entwicklungsumgebung und Entwicklungswerkzeuge	Milan Naybzadeh über Comala am 07.10.2019	11.10.2019	Michael Seefried
1	Initiale Version	Andreas Bachmann über Comala am 03.07.2019	03.07.2019	Michael Seefried